

Contentious Chamber

Decision on the merits 62/2024 of April 25, 2024

File number: DOS-2020-00171

Subject: Security and use of the national register number in an online appointment scheduling system

The Contentious Chamber of the Data Protection Authority, composed of

Mr. Hielke Hijmans, president, and Messrs. Dirk Van Der Kelen and Jelle Stassijns, members;

Having regard to Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter "GDPR");

Having regard to the law of December 3, 2017, establishing the Data Protection Authority, hereinafter "LCA";

Having regard to the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Having regard to the documents in the file;

Has made the following decision regarding:

The complainant:

Mrs. X, hereinafter "the complainant";

The defendant:

Y, hereinafter "the defendant"

Decision on the merits 62/2024 — 2/18

I. Facts and procedure

1.

On February 10, 2020, the complainant filed a complaint with the Data Protection Authority against the defendant.

2.

The subject of the complaint concerns the use of the national register identification number in the defendant's online appointment scheduling system and the related technical and organizational (security) measures.

3.

On March 5, 2020, the complaint was declared admissible by the Frontline Service based on Articles 58 and 60 of the LCA, and the complaint was forwarded to the Contentious Chamber under Article 62, § 1 of the LCA.

4.

On March 26, 2020, in accordance with Article 96, § 1 of the LCA, the Contentious Chamber's request to conduct an investigation was forwarded to the Inspection Service, along with the complaint and the inventory of documents.

5.

On May 4, 2020, the investigation by the Inspection Service was concluded, the report was attached to the file, and it was forwarded by the General Inspector to the President of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA).

The report of the Inspection Service contains the following findings:

1. Violation of Article 30.2 of the GDPR due to an incomplete and inaccurate record of processing activities;

2. Violation of Article 32.1 of the GDPR due to the absence of appropriate technical and organizational measures, and violation of Article 32 of the GDPR due to insufficient cooperation with the Inspection Service's investigation;

3. No violation of Article 28.3 of the GDPR following the presentation of subcontracting contracts by the defendant;

4. Violation of Article 37.1 of the GDPR due to the absence of the designation of a data protection

officer;

5. Processing of the national register number by the defendant on behalf of its clients.

6.

On November 20, 2020, the Contentious Chamber decided, based on Article 95, § 1, 1° and Article 98 of the LCA, that the file could be examined on the merits and informed the parties concerned by registered mail of the provisions as stated in Article 95, § 2 and Article 98 of the LCA. They were also informed, under Article 99 of the LCA, of the deadlines for submitting their conclusions.

The deadline for receiving the complainant's response conclusions was set for December 11, 2020, and the deadline for the defendant's reply conclusions was set for January 4, 2021.

Decision on the Merits 62/2024 — 3/18

7.

On November 24, 2020, the defendant accepts all communications related to the case electronically and expresses his intention to submit conclusions, in accordance with Article 98 of the LCA.

8.

On December 10, 2020, the Litigation Chamber receives the plaintiff's reply conclusions. The plaintiff states that she acknowledges the violations as established by the Inspection Service. The plaintiff also argues that the use of the National Register number as a unique identifier currently appears to be unlawful and requests that it be demonstrated that the defendant falls under an exception as referred to in Article 8 of the law of August 8, 1983 organizing a national register of natural persons.

Furthermore, the plaintiff refers to Article 13 of the aforementioned law regarding the consequences of unlawful use of the National Register number. In this regard, the plaintiff states that she assumes the defendant will request or has already requested permission to use the National Register number in the meantime.

9.

On January 4, 2021, the Litigation Chamber receives the defendant's reply conclusions, which essentially state that he processes data on behalf of the data controllers who responded to his SaaS offer, which is why he claims to act as a subcontractor. The defendant responds to each finding of the Inspection Service and submits arguments and evidence to refute the violations identified by the Inspection Service. Furthermore, the defendant also objects that the plaintiff's interest has not been demonstrated and that she is likely working for a competing company that offers a similar software solution.

10.

On September 6, 2023, the parties are informed that the Litigation Chamber is proceeding ex officio to schedule a hearing, set for November 23, 2023.

11.

On September 6, 2023, the Litigation Chamber receives an email from the plaintiff informing that the complaint is no longer applicable, as several medical appointment booking platforms now use the National Register number so that doctors can link their patients to medical record platforms.

12.

On September 27, 2023, the Litigation Chamber responds to the plaintiff's message indicating that despite the withdrawal of her complaint, it has been decided to continue the examination of the complaint. What prevails in this regard is that once seized, the Litigation Chamber is authorized to examine compliance with the GDPR and to ensure its effective application independently, even if the complaint has been withdrawn by the complainant or has become moot.

13.

On October 26, 2023, the date of the hearing is postponed to December 14, 2023.

1 Software as a Service.

Decision on the Merits 62/2024 — 4/18

14.

On December 11, 2023, the plaintiff informs the Litigation Chamber that she will not be present at the hearing.

15.

On December 14, 2023, the defendant is heard by the Litigation Chamber. Although duly summoned, the plaintiff does not participate in the hearing.

16.

On December 21, 2023, the minutes of the hearing are submitted to the parties.

17.

On December 22, 2023, the Litigation Chamber receives two remarks from the defendant regarding the minutes, which it decides to include in its deliberation.

II. Reasoning

a) Interest of the Plaintiff

18.

The defendant notes that the plaintiff seems to pursue other purposes, namely to gain knowledge and understanding of the defendant's business and activities. She is not seeking to remedy the harm she may have suffered as a data subject. In this regard, the defendant argues that at no time did the plaintiff contact the designated contact person responsible for privacy within her organization, but instead decided to immediately file a complaint, failing to demonstrate how she could be harmed in terms of data protection.

19.

The Litigation Chamber states that, in principle, it does not verify the purpose of the complainant when a complaint is filed. However, it considers the extent to which a complainant has an interest. Regarding the interest of the plaintiff, the Litigation Chamber draws attention to the following:

20. Article 58 of the LCA states: "Any person may file a complaint or a written request, dated and signed, with the Data Protection Authority." In accordance with Article 60, paragraph 2 of the LCA, "A complaint is admissible when it:

- is written in one of the national languages;
- contains a statement of facts and the necessary information to identify the processing to which it relates;
- falls within the competence of the Data Protection Authority."

21.

The preparatory works of the LCA state: "Any person may file a complaint or a request with the Data Protection Authority: natural persons, but also legal persons, associations, or institutions wishing to report an alleged violation of the regulation. A complaint or request addressed to the Data Protection Authority must be written, dated, and signed by the...

Decision on the merits 62/2024 — 5/18

competent person in the matter. A request must be interpreted in the broadest sense of the word (request for information or explanation, request for mediation, ...)2.

22.

The LCA does not exclude that a person other than the data subject or the person authorized by the data subject, as defined in Article 220 of the law of July 30, 2018, on the protection of natural persons with regard to the processing of personal data, may file a complaint with the Authority.

23.

Although the GDPR considers the 'complaint' from the perspective of the data subject, imposing obligations on supervisory authorities when a person files a complaint (see Articles 57, 1.f) and 77 of the GDPR), the GDPR does not prevent national law from allowing other persons than the data subjects to file a complaint with the national supervisory authority. The possibility of such a referral corresponds to the missions assigned to supervisory authorities by the GDPR. In this regard and generally, each supervisory authority: ensures the enforcement of the GDPR and compliance with it (Article 57.1.a) of the GDPR) and carries out any other mission related to the protection of personal data (Article 57.1.v) of the GDPR)3.

24.

The Contentious Chamber considers in this regard that Article 58 of the LCA gives any person the possibility to file a complaint, provided that they have a sufficient interest, in accordance with the aforementioned provisions of the GDPR.

25.

However, the condition is that the complainant demonstrates a sufficient interest. In this regard, the Contentious Chamber emphasizes that based on the documents in the file, the complainant only mentions the fact that she consulted the website [...], which uses the defendant's online appointment system. This simple fact leads the complainant to assume that the national register number is stored in the defendant's database, without providing any document demonstrating that the complainant is affected in the protection of her personal data. The website in question can indeed be accessed freely by anyone, which allows the complainant to allege, on this simple basis and without any data processing being required for this purpose, potential violations of the security of personal data by the defendant and a possible improper use of information, particularly the national register number.

26.

Given that the complainant does not demonstrate that the defendant processes personal data concerning her and that she also does not prove a sufficiently concrete interest to file a complaint, the Contentious Chamber further finds that the complainant also lacks the standing to be able to

2 Doc. parl., House of Representatives, 2016-2017, DOC 54 2648/001, p. 40 (note on Article 58 of the initial draft law).

3 In its decision of June 8, 2020, the Contentious Chamber already admitted, under very strict conditions, that a person other than the data subject could file a complaint (Decision on the merits 30/2020, published on the website of the DPA).

Decision on the Merits 62/2024 — 6/18

to file a complaint and that consequently, the entire procedure is tainted by the absence not only of an interest but also of standing on the part of the complainant.

b) Standing of the Defendant

27.

In order to determine the obligations incumbent upon the defendant under the GDPR, it is necessary to first ascertain in what capacity the defendant is involved in relation to the processing of data that is the subject of the complaint. The crucial point in this regard is to determine whether the defendant acts as a data controller (Article 4.7) of the GDPR⁴ or as a processor (Article 4.8) of the GDPR⁵.

28.

The inspection report specifies that the defendant was the subject of the investigation in its capacity as a processor concerning the personal data of clients for whom it processes personal data. The defendant also argues that it only acts as a processor, not as a data controller. The Contentious Chamber verifies whether the premise that the defendant should only be regarded as a processor corresponds to the (broad) interpretation of the notion of data controller by the Court of Justice⁶ and the European Data Protection Board (EDPB), particularly in the Guidelines 07/2020 regarding the notion of data controller.

29.

The GDPR defines a "data controller" as an entity that, alone or jointly with others, determines the purposes and means of the processing of personal data⁷. This definition must be understood in light of the legislator's purpose of attributing primary responsibility for the protection of personal data to the entity that actually exercises control over the processing.

4 Article 4 of the GDPR:

"For the purposes of this Regulation, the following definitions apply:

[...]

7) 'data controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing; where the purposes and means of such processing are determined by Union law or the law of a Member State, the data controller may be designated or the specific criteria for its designation may be provided for by Union law or the law of a Member State;"

5 Article 4 of the GDPR:

"For the purposes of this Regulation, the following definitions apply:

[...]

8) 'processor' means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the data controller;"

6 See, inter alia, CJEU, Judgment of July 10, 2018, Jehovah's Witnesses, C-25/17, ECLI:EU:C:2018:551, para. 66, and more recently the judgment of March 7, 2024, IAB Europe, C-604/22, ECLI:EU:C:2024:214, para. 55.

7 Art. 4(7) of the GDPR

Decision on the merits 62/2024 — 7/18

of data. This implies that one must not only consider the legal qualification but also the factual reality.

30. The EDPB clarified that the concept of the data controller is based on the influence of the data controller over the processing, based on decision-making competence or control over processing activities. Such control may arise from legal provisions, implicit competence, or be based on the exercise of de facto influence. In essence, the determination of the purposes and means corresponds to the determination of the why and how of the processing: for a particular processing activity, the data controller is the one who exercises this influence over the processing of personal data and thus determines why the processing takes place (i.e., for what purposes or why) and how this objective will be achieved (i.e., what means must be used to achieve the objective).

31. The competence to determine the means and purposes of processing activities may first be linked to the functional role of an organization. Furthermore, responsibility may be attributed based on contractual provisions between the parties involved, although these provisions are not always decisive, or based on an assessment of the factual control of a party. Thus, the determination of the means and purposes may result from a determining influence on the processing, more specifically on the reason why a processing is carried out in a certain manner.

32. In its ruling on the Jehovah's Witnesses, the Court of Justice provides a detailed explanation regarding the notion of data controller. This ruling emphasizes that the definition of data controller must be interpreted broadly in order to ensure "effective and complete protection of the data subjects," and that it is not...

8 L. A. BYGRAVE & L. Tosoni, "Article 4(7). Controller" in The EU General Data Protection Regulation. A commentary, Oxford University Press, 2020, p. 148.

9 EDPB – Guidelines 07/2020 on the concepts of controller and processor in the GDPR, v 2.0, 2021, paragraph 20 e.s.

10 Ibid., paragraph 35.

11 D. De Bot, The application of the General Data Protection Regulation in the Belgian context, Wolters Kluwer, 2020, paragraphs 362.

12 D. De Bot, The application of the General Data Protection Regulation in the Belgian context, Wolters Kluwer, 2020, paragraphs 363-365.

13 EDPB – Guidelines 07/2020 on the concepts of controller and processor in the GDPR, v 2.0, 2021, paragraph 20.

14 CJEU, Judgment of July 10, 2018, Jehovah's Witnesses C-25/17, ECLI:EU:C:2018:551.

15 CJEU Judgment of May 13, 2014, Google Spain and Google, C-131/12, ECLI:EU:C:2014:317, paragraph 34; see also the discussion regarding the scope of the notion in C. DOCKSEY and H. HIJMANS, "The Court of Justice as a Key Player in Privacy and Data Protection," European Data Protection Law Review, 2019, Vol. 3, (300)304.

Decision on the merits 62/2024 — 8/18

necessary to have access to the personal data subject to processing to be considered as the data controller¹⁶.

33. The determining factors for establishing whether data processing occurs as a data controller or as a processor are the purposes and means, more specifically the extent to which there is decision-making power in this regard.

34. In concrete terms, the data processing in this case is carried out by the defendant using software that consists of an appointment scheduling system based on Internet technology. To assess the defendant's impact on the purpose and means, it is first necessary to understand how this application works. It operates as follows:

- a. The patient browses the medical practice's website or uses the application;
- b. The patient identifies themselves in the online calendar system. The application user, in this case the healthcare provider, chooses the patient's connection method, namely via 1) a username and password; 2) name, surname, and date of birth; 3) e-ID; 4) national registry number; or 5) a social media account;
- c. The patient selects the doctor with whom they wish to make an appointment;
- d. The patient optionally selects a type of appointment;
- e. The patient chooses the desired time slot;
- f. The patient optionally adds additional remarks;
- g. The patient confirms their appointment.

35. The defendant then checks whether the relevant personal data of the concerned patient is present in the healthcare provider's database. If so, the patient can make an appointment. If not, either the patient can register manually, or access is denied if the healthcare provider does not wish to accept new patients. The investigation conducted by the Inspection Service established that the defendant does not transfer any personal data of patients to the mentioned social media managers.

36. Based on the elements of this case, the Contentious Chamber finds that the purpose pursued is to have an online scheduling system that allows for making appointments and receiving appointment reminders, exchanging data with other applications, and making appointments in a fully automated manner by phone. This purpose arises from the necessity for the healthcare provider to be able to

16 CJEU, Judgment of July 10, 2018, Tietosuojavaaltuutettu and Jehovan todistajat – religious community, C-25/17,

ECLI:EU:C:2018:551. See also EDPB - Guidelines 07/2020 on the concepts of data controller and processor in the GDPR, v 2.0, 2021, paragraph 45.

Decision on the merits 62/2024 — 9/18

to record appointments with patients efficiently and effectively.

This means that the purpose is determined entirely autonomously by the healthcare provider and that the defendant's online scheduling system is merely a means to achieve this purpose. In this regard, it is established that only those healthcare providers who believe that the application proposed by the defendant, with the features offered by the online scheduling system for recording appointments with patients, meets their specific needs, will effectively also resort to the defendant and enter into a contract with him. The healthcare provider therefore does not solely decide on the purpose but entirely independently decides on the means that he considers most appropriate to achieve the purpose he pursues.

37.

In this context, the defendant plays a purely intermediary role in the sense that he merely presents and proposes the various features of the application. However, it is exclusively the healthcare provider who, depending on the purpose he pursues, chooses from the options offered by the application the features he wishes to use. Since both the purpose and the means to achieve it are determined exclusively by the healthcare provider, it is therefore appropriate to attribute to him the status of data controller.

38. The defendant, on the other hand, meets the two main conditions¹⁷ to be qualified as a processor within the meaning of Article 4. 8) of the GDPR, namely:

- a) he is a distinct legal entity, independent of the data controller, in this case, the healthcare provider, and
- b) this entity processes personal data on behalf of the data controller.

39. Healthcare providers, generally a practice of healthcare providers, decide to subcontract the activity of recording appointments with patients to the defendant, an external organization completely independent of the practice to which the healthcare providers belong. The defendant also possesses the required legal personality, as he has adopted the form of a limited liability company.

40. The subcontracting contract that the defendant provided in the context of the

Inspection Service's investigation shows that the processing activity is carried out under the strict obligation for the defendant to execute it in accordance with the written instructions of the healthcare provider and solely according to those instructions. The Contentious Chamber finds that in this regard, there is not the slightest margin for the defendant to process the personal data obtained for any other purpose of his own. There it is

17

EDPB

–

Guidelines

07/2020

on

the

notions

of

data controller and processor in the GDPR, v 2.0, 2021, paragraphs 73 - 84.

Decision on the merits 62/2024 — 10/18

also explicitly stated that the defendant will not process personal data for any purpose other than that defined by the healthcare provider, and in this regard, the requirement set out in Article 28.10 of the GDPR to be considered a processor is satisfied. Indeed, any purpose concerning the data obtained is completely absent on the part of the defendant, who processes this data solely on behalf of the healthcare provider.

41.

The defendant's status as a processor is further confirmed by the fact that the specific processing activity of the defendant, as a service provider that processes the personal data of the patient in the context of its relationship with the healthcare provider to facilitate the scheduling of an appointment between the patient and the healthcare provider, occurs on behalf of the healthcare provider, which has absolute control over the data processing. In this regard, the nature of the service is crucial in that, to be classified as a processor, the service provided must be specifically focused on the processing of personal data, or the processing carried out must constitute an essential aspect of this service. The software application provided by the defendant is primarily focused on the processing of personal data of patients as supplied by the healthcare provider and which is necessary for the scheduling of appointments, and only appointments, with the relevant healthcare provider, without the defendant offering in this context any management of health data records and without having any influence on the determination of the purposes and means of the processing.

42.

Given that the Disciplinary Chamber considers it established that the defendant acts as a processor, this has implications for the obligations related to data protection that arise from this status. The findings of the Inspection Service must therefore be examined in light of this element.

c) Obligations of the defendant

1° Register of processing activities

43. Based on the two registers of processing activities submitted by the defendant, the Inspection Service found that the contact details of the data controller on behalf of whom the defendant acts as a processor were missing, which is not in compliance with Article 30.2.a) of the GDPR. The Inspection Service adds that the readability of the two registers is hindered by numerous references to annexes for clarifications.

44. The defendant argues that the finding of the absence of the contact details of the data controller in the computer file containing information related to the essential elements of the register of processing activities cannot lead to the conclusion of a violation of Article 30.2.a) of the GDPR, given that the contact details of the data controller

Decision on the Merits 62/2024 — 11/18

processing were mentioned in the letter accompanying the register of processing activities. The accompanying letter and the register of processing activities must be read together, according to the

defendant.

45. Regarding the lack of clarity of the register of processing activities, the defendant argues that it is appropriate for the provision of data to use multiple linked tables forming clusters. The defendant indicates that he chose to subdivide the register into several levels through references to the annexes, as providing access to all information in a single table would precisely result in rendering the register unintelligible. In this regard, the defendant emphasizes the purpose of the register of processing activities, which is not intended for the data subject, but rather for the Data Protection Authority (hereinafter "DPA") that uses it as a 'tool' for providing information that allows it to verify what the processing activities are.

46. Given that following the request from the Inspection Service to present the register of processing activities, the defendant provided all the information, including the contact details of the data controller on behalf of whom the defendant acts as a processor, in order to allow the Inspection Service to carry out its monitoring mission, it follows that the purpose of Article 30.2 of the GDPR is achieved. The register of processing activities indeed aims to enable the DPA, of which the Inspection Service is a part, to monitor the processing activities. The possibility of exercising this control has at no time been compromised by any lack of information, so the defendant has not failed in his obligation to cooperate with the DPA, as he spontaneously provided the Inspection Service, upon first request, with the register of processing activities along with the contact details of the data controller on behalf of whom the personal data were processed. Although it is preferable that the contact details of the data controller on behalf of whom the processor carries out the data processing also appear in the register of processing activities itself, in order for the defendant to fully comply with the data that must be mandatorily included in the register, the Contentious Chamber considers that the defendant has fulfilled his obligation to provide all the information required under Article 30.2 of the GDPR.

47. Regarding how the information is presented in the register of processing activities, the Contentious Chamber notes that the GDPR does not impose any intrinsic form requirement that would prohibit stratified access to the information in

18 See also in this regard Recital 82 of the GDPR: "In order to demonstrate compliance with this Regulation, the data controller or the processor should maintain records of processing activities under its responsibility. Each data controller and processor should be obliged to cooperate with the supervisory authority and to make these records available to it, upon request, for the purpose of monitoring processing operations."

Decision on the Merits 62/2024 — 12/18

referring to annexes. The Inspection Service observes that the numerous references to the annexes hinder the readability of the record of processing activities, but without finding that this would prevent the Inspection Service from obtaining an overview of the processing activities carried out by the defendant. The Inspection Service was therefore able to fulfill its monitoring mission.

48. In light of the above, the Disciplinary Chamber considers that no violation of Article 30.2 of the GDPR has been committed.

2° Data Protection Officer

49. The report of the Inspection Service indicates that, contrary to what the defendant claims, a data protection officer should have been appointed. According to the Inspection Service, the defendant processes personal data of patients on a large scale, including health data, and the online appointment system requires regular and systematic monitoring of the appointments that these patients make with their doctor, which obliges the defendant to appoint a data protection officer, in accordance with Article 37.1 of the GDPR.

50. The defendant refutes the regular and systematic large-scale monitoring of the data subjects (Article 37.1.b) of the GDPR) by arguing that it is not established that appointments are regularly made through the defendant's software application, given that the patient is not required to use it. The patient is indeed free to attend the consultation without an appointment or to make an appointment by phone, without any intervention from the defendant. It is also possible, according to the defendant, that a patient consults a doctor a maximum of 1 or 2 times a year, so that regularity cannot be questioned either.

51. This analysis is relevant, in light of Article 37.1.b) of the GDPR which requires regular and systematic monitoring. The concepts of "regular" and "systematic" are not defined in the GDPR, but an interpretation is provided in the Guidelines on Data Protection Officers¹⁹. The possible interpretation given to the notion of "regular" is:

- continuous or occurring at regular intervals over a given period;
- recurring or repeating at fixed times;
- taking place consistently or periodically.

The notion of "systematic" is defined as follows:

19 These Guidelines from the Article 29 Working Party were approved on December 13, 2016, last revised and approved on April 5, 2017, and ratified by the European Data Protection Board.

Decision on the merits 62/2024 — 13/18

- occurring in accordance with a system;
- pre-established, organized, or methodical;
- taking place within the framework of a general data collection program;
- carried out as part of a strategy.

52. The Contentious Chamber deduces from the examples provided in the aforementioned Guidelines of processing that may constitute regular and systematic monitoring of the data subjects²⁰ that behavioral monitoring is not isolated, but is always accompanied by a specific purpose. According to the Contentious Chamber, the recording of an appointment between a healthcare provider and a patient is distinguished in that no other purpose is pursued other than the mere scheduling of an appointment, which is completely unrelated to any monitoring of the behavior of the concerned patient. The data obtained is exclusively used to set an appointment. There is no indication that this same data is analyzed to associate it with any consequence or purpose, so it cannot be concluded that it aims to subject the concerned patients to any form of regular or systematic monitoring.

53. Regarding the large-scale nature of the processing of specific categories of personal data within the meaning of Article 9 of the GDPR, the defendant emphasizes both in the reply conclusions and during the hearing that there is no management of health data files, but that the application merely enables the scheduling of an appointment, which at most allows for the deduction that the concerned person may be ill. The large-scale nature of the data processing is also refuted by the defendant, who points out that the data processing in question is distinguished from the data processing by a hospital or an insurance organization, which must indeed be qualified as being on a large scale. Viewed from this angle, the defendant believes that the appointment of a data protection officer is therefore not required.

54. In order to determine whether the defendant must have a data protection officer or not, the Contentious Chamber examined the elements brought to its attention in the context of this case in light of the Guidelines on data protection officers²¹. Given that according to Article 37.1 b) and c) of the GDPR, data processing must be carried out "on a large scale," but that the interpretation

20 Examples of activities that may constitute regular and systematic monitoring of data subjects: operation of a telecommunications network; provision of telecommunications services; email retargeting; data-driven marketing activities; profiling and scoring for risk assessment purposes (for example, for credit risk assessment, insurance premium setting, fraud prevention, or money laundering detection); geolocation, for example, through mobile applications; loyalty programs; behavioral advertising; monitoring of data on well-being, health, and fitness through wearable devices; closed-circuit television systems; connected devices such as cars and smart meters, home automation, etc.

21 https://ec.europa.eu/newsroom/just/document.cfm?doc_id=44100.

Decision on the merits 62/2024 — 14/18

the meaning to be given to these terms is not further defined, the aforementioned Guidelines provide a number of factors to determine whether processing is carried out on a large scale or not. These factors are as follows:

- the number of data subjects, either in absolute terms or relative to the population concerned
- the volume of data and/or the range of data processed

- the duration, or permanence, of the data processing activities
- the geographical extent of the processing activity.

55. As stated in Recital 91 of the GDPR, the Guidelines regarding data protection officers also indicate that the processing of personal data cannot be considered large scale if it involves the processing of personal data of patients or clients by a doctor or another healthcare professional acting on an individual basis. According to Recital 91 of the GDPR, such processing should therefore not be regarded as large scale in the sense of processing aimed at handling a considerable volume of personal data at the regional, national, or supranational level, which may affect a significant number of data subjects and is likely to result in a high risk, for example, due to their sensitive nature, when, in accordance with the state of technological knowledge, a new technique is applied on a large scale, or in the sense of other processing operations that pose a high risk to the rights and freedoms of data subjects, particularly when, due to these operations, it becomes more difficult for these individuals to exercise their rights. In the present case, the Contentious Chamber also takes into account the fact that, as a subcontractor, the defendant processes data on behalf of the healthcare provider. The fact that the healthcare provider entrusts data processing to a subcontractor does not affect the absence of "large scale" character of the processing. Furthermore, the defendant only processes the patient identification data that are relevant to schedule an appointment in the healthcare provider's agenda and that ensure unique identification without any associated management of health data records. The mere inference from scheduling an appointment with a healthcare provider that a patient may be ill is not sufficient to classify this processing, whose purpose is limited to making an appointment, as risky.

56. Therefore, the Contentious Chamber considers that no violation of Article 37.1 of the GDPR has been committed.

Decision on the merits 62/2024 — 15/18

d) Use of the National Register number and security measures

57.

Regarding the use of the National Register number by the defendant, the Inspection Service's report merely states that the use or non-use of the National Register number in the defendant's online appointment system depends on the choice made in this regard by the client, namely the healthcare provider or the defendant's healthcare provider office, since it is the client who chooses the patient's connection method to the system. The Inspection Service does not find any infringement concerning the use of the National Register number but limits itself to noting that the defendant processes the National Register number on behalf of its clients.

58. The Disciplinary Chamber considers that the Inspection Service's finding that the client chooses the connection method for the patient, and that this choice does not fall to the defendant, confirms that the client, namely the healthcare provider, is the data controller (see above point 'b) Quality of the defendant'), and that the latter must have the authorization to use the National Register number if it decides that the patient can connect using their National Register number. The defendant can therefore apply this connection method and use this number only to the extent that the healthcare provider is itself authorized to use the National Register number in accordance with Article 8 of the law of August 8, 1983, organizing a national register of natural persons. This is possible based on legislation that provides for the use of the National Register number or based on an authorization to use this number. As necessary, the Disciplinary Chamber recalls that a deliberation granting authorization must be considered a more specific provision in national law within the meaning of Articles 6.2 and 6.3 of the GDPR, which thus has legal significance.

59. Although this point is not the subject of the complaint and is therefore not at issue, it is indeed essential to determine to what extent and under what conditions the defendant can process the National Register number. The Disciplinary Chamber draws attention to the fact that healthcare providers with whom the patient has a therapeutic relationship are authorized to use the National Register number of the patient concerned to, among other things, access the overall medical record. The National Register number constitutes, in this regard, the key to unique identification, the importance of which must be emphasized, given the patient's health, which is at the heart of the process, and any risk of identity confusion must be excluded. Based on the above, the Disciplinary

Chamber concludes that the defendant, who processes the National Register number in its database in the form of its hash, on behalf of the data controller, namely the healthcare provider, does so lawfully to the extent that it meets all obligations imposed by the GDPR on a processor, including the conclusion

Decision on the merits 62/2024 — 16/18

of a subcontracting contract. The Inspection Service explicitly noted in its report that the defendant did not commit any violation of Article 28.3 of the GDPR²².

60. In accordance with Article 28.1 of the GDPR, the defendant acting as a processor must provide sufficient guarantees regarding the implementation of appropriate technical and organizational measures so that the processing meets the requirements of the GDPR and ensures the protection of the rights of the data subject. The Inspection Service obtained information from the defendant to assess whether it meets the requirements of Article 32 of the GDPR, but considers that this response contains a very general description and a list of measures that would have been taken, without attaching the requested copy of the documents. Based on the above, the Inspection Service finds that there is a violation of Article 32.1 of the GDPR and Article 31 of the GDPR.

61.

The defendant claims to have transparently explained how the application works and where personal data is stored. To this end, it refers to its response by letter dated April 29, 2020. According to the defendant, these elements, as well as the detailed list of technical and organizational measures, provide the Inspection Service with a sufficient understanding of the situation. Regarding the remark made in the Inspection Service's report that the defendant could have provided

22 Article 28.3. "Processing by a processor shall be governed by a contract or other legal act under Union law or the law of a Member State, which binds the processor to the controller, sets out the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. This contract or other legal act shall provide, in particular, that the processor:

- a) shall process the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or to an international organization, unless required to do so by Union law or the law of the Member State to which the processor is subject; in this case, the processor shall inform the controller of that legal requirement before processing, unless the law in question prohibits such information for important reasons of public interest;
- b) shall ensure that persons authorized to process the personal data are committed to confidentiality or are under an appropriate statutory obligation of confidentiality;
- c) shall take all measures required pursuant to Article 32;
- d) shall respect the conditions laid down in paragraphs 2 and 4 for engaging another processor;
- e) shall take into account the nature of the processing, assist the controller, by means of appropriate technical and organizational measures, insofar as is possible, in fulfilling its obligation to respond to requests for exercising the rights of data subjects laid down in Chapter III;
- f) shall assist the controller in ensuring compliance with the obligations pursuant to Articles 32 to 36, taking into account the nature of the processing and the information available to the processor;
- g) at the choice of the controller, shall delete all personal data or return it to the controller at the end of the provision of services relating to the processing, and shall delete existing copies, unless Union law or the law of the Member State requires storage of the personal data; and
- h) shall make available to the controller all information necessary to demonstrate compliance with the obligations laid down in this Article and to allow for audits, including inspections, by the controller or another auditor mandated by the controller, and contribute to such audits.

Regarding point h) of the first paragraph, the processor shall inform the controller immediately if, in its opinion, an instruction infringes this Regulation or other provisions of Union or Member State law relating to the protection of personal data."

Decision on the merits 62/2024 — 18/18

Such an appeal may be introduced by means of a contradictory application which must include the

mentions listed in Article 1034^{ter} of the Judicial Code²⁴. The contradictory application must be filed with the registry of the Market Court in accordance with Article 1034^{quinquies} of the Judicial Code²⁵, or via the e-Deposit IT system of Justice (Article 32^{ter} of the Judicial Code).

(signed) Hielke HIJMANS

President of the Litigation Chamber

24 "The application contains, under penalty of nullity:

1° the indication of day, month, and year;

2° the name, first name, and address of the applicant, as well as, where applicable, their capacity and national register number or business number;

3° the name, first name, address, and, where applicable, the capacity of the person to be summoned;

4° the subject and a brief summary of the grounds of the application;

5° the indication of the judge who is seized of the application;

6° the signature of the applicant or their lawyer."

25 "The application, accompanied by its annex, is sent, in as many copies as there are parties involved, by registered letter to the clerk of the court or filed at the registry."